

MEDISYNC SOLUTIONS

INFORMATION SECURITY POLICY

CONFIDENTIAL | INTERNAL USE ONLY

Document ID:	POL-001
Version:	1.0
Owner:	CISO — Isha Gupta
Approved by:	CEO — Marcus Chen
Effective Date:	September 1, 2026
Review Date:	September 1, 2027
ISO 27001 Ref:	Clause 5.2, A.5.1, A.5.2, A.5.36
HIPAA Ref:	§164.308(a)(1), §164.316

1. Purpose

This Information Security Policy establishes MediSync Solutions' commitment to protecting the confidentiality, integrity, and availability of all information assets — including approximately 2.3 million patient records and Protected Health Information (PHI) processed on behalf of 47 hospital systems, 312 physician practices, and 8 accountable care organizations. It defines the principles, roles, and obligations governing MediSync's Information Security Management System (ISMS) as MediSync prepares for ISO 27001:2022 certification and maintains SOC 2 Type II and HIPAA compliance.

2. Scope

This policy applies to all 78 MediSync employees, contractors, and third-party personnel; all systems including the MediSync Care Platform, MediSync Mobile, FHIR API gateway, AWS infrastructure (us-east-1 primary, us-west-2 DR), Okta, Splunk Cloud, Qualys, and GitHub Enterprise; all Cleveland HQ on-premises systems; and all data across MediSync's four classification tiers: Critical (PHI, credentials), Confidential (contracts, financials), Internal (employee data), and Public.

3. Security Principles

3.1 Confidentiality

PHI and sensitive information are accessible only to authorized individuals on a need-to-know, minimum-necessary basis. Access to the Care Platform, AWS RDS, and S3 PHI storage is role-restricted via Okta RBAC.

3.2 Integrity

Information is protected from unauthorized modification. All changes to PHI, security configurations, and source code are reviewed, approved, and logged in Splunk Cloud and AWS CloudTrail.

3.3 Availability

Critical systems — particularly the Care Platform — must meet a 4-hour Recovery Time Objective (RTO). MediSync's AWS Multi-AZ deployment and us-west-2 DR environment support this requirement.

4. Roles and Responsibilities

- CEO (Marcus Chen): approves this policy annually; accountable to the board for security program
- CTO (Priya Nair): ensures security requirements are embedded in all technology decisions
- CISO (Isha Gupta): owns the ISMS; approves risk treatment; reports quarterly to executive leadership
- GRC Analyst: maintains policies, conducts risk assessments, coordinates audits and compliance activities
- IT Manager (James Okonkwo): implements and maintains technical controls; manages access provisioning
- Security Engineers (2): configure AWS security controls, monitor Splunk alerts, manage EDR and WAF
- All Employees: comply with this policy; complete annual security training; report incidents to security@medisync.com

5. Policy Statements

MediSync Solutions shall:

- Maintain an ISMS aligned to ISO 27001:2022 covering all systems that process, store, or transmit PHI or Confidential information
- Conduct formal risk assessments at least annually; document results in the MediSync Risk Register; obtain CISO approval for all risk treatment decisions
- Implement security controls proportionate to risk, with PHI systems receiving the highest level of protection
- Require all employees and contractors to complete security awareness training within 30 days of hire and annually thereafter; target completion rate: 95%
- Maintain and test an Incident Response Plan capable of detecting, containing, and recovering from security incidents within defined timeframes per POL-004
- Maintain Business Associate Agreements (BAAs) with all vendors who access, process, or store PHI, including all 12 EHR integration partners
- Conduct vulnerability assessments at least monthly using Qualys; remediate Critical CVEs within 15 days and High CVEs within 30 days
- Conduct an annual penetration test of the Care Platform and AWS environment; remediate findings per risk level
- Protect all PHI in transit using TLS 1.2 or higher; protect PHI at rest using AES-256 encryption via AWS KMS
- Retain security documentation, audit logs, and access records for a minimum of 6 years in compliance with HIPAA requirements

6. Enforcement

Violations of this policy are subject to disciplinary action up to and including termination of employment or contract. Violations involving PHI may trigger regulatory reporting obligations under HIPAA/HITECH and applicable state privacy laws in Ohio, Florida, Texas, and California. MediSync reserves the right to pursue civil or criminal remedies for intentional violations.

7. Exceptions

Exceptions to this policy require written documentation of business justification and compensating controls, written CISO approval prior to implementation, a defined time limit (maximum 90 days initial duration), and registration in the exceptions register maintained by the GRC Analyst. Exception requests are submitted to security@medisync.com.

8. Review Cycle

This policy is reviewed annually by the CISO and approved by the CEO. Reviews are also triggered by significant security incidents, major changes to technology infrastructure, changes to applicable regulations, or audit findings. All employees are notified of updates within 5 business days of approval and must acknowledge the updated policy within 30 days.

Next review: September 1, 2027 | Document owner: CISO, MediSync Solutions | POL-001 v1.0